

BERGISCHE
UNIVERSITÄT
WUPPERTAL

Master's Thesis Proposal in M.Sc. Informatik

A security analysis of ZUGFeRD electronic invoice validation

Simon Krahé

June 7, 2026

Robust, Secure and Privacy-Preserving Smart Systems
School of Electrical, Information and Media Engineering
University of Wuppertal

Advisor:	**Prof. Dr. Christian Mainka** **Titus Vollbracht, M.Sc.**
First Examiner:	**Prof. Dr. Christian Mainka**
Second Examiner:	**Prof. Dr. Tibor Jager**

Eigenständigkeitserklärung

Hiermit erkläre ich, dass ich keine Arbeit in gleicher oder ähnlicher Fassung bereits als Prüfungsleistung an der Bergischen Universität Wuppertal oder einer anderen Hochschule eingereicht habe.

Ich versichere, dass die vorliegende Arbeit auf meiner konzeptionellen, methodischen und inhaltlichen Eigenleistung basiert und ich keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Alle direkten und indirekten Zitate sowie KI-generierten fachlichen Inhalte habe ich unter Angabe der Quellen kenntlich gemacht. Diese Versicherung bezieht sich auf alle Textbausteine, Tabellen, Codes, Grafiken und andere Abbildungen. Mir ist bewusst, dass die Unterlassung der angemessenen Dokumentation mit einem Täuschungsversuch aufgrund der Verwendung nicht zulässiger Hilfsmittel gleichzusetzen ist.

Im Falle der Verwendung von KI-Tools habe ich allen Output sorgfältig geprüft und übernehme die volle Verantwortung für eventuell durch die KI generierte fehlerhafte oder verzerrte Inhalte, fehlerhafte Referenzen, Verstöße gegen das Datenschutz- und Urheberrecht oder Plagiate.

Ich erkläre mich außerdem damit einverstanden, dass die digitale Version dieser Arbeit zwecks Plagiatsprüfung verwendet wird.

Declaration of Authorship

I hereby declare that I have never before submitted this paper in this or similar form for examination at Bergische Universität Wuppertal or any other institution or university.

I profess that this paper is the result of my own conceptional, methodical and analytical work and that I have not used any sources or tools other than the ones stated. Any quotes, whether direct or indirect, and any substantial content that was generated with the help of AI have been fully disclosed by using proper marking and quotation. This declaration is valid for all textual elements, charts, codes, images and figures. I am aware that neglecting the proper documentation constitutes an attempt at deception by use of unauthorized aid.

When using AI tools, I have critically reviewed and verified all output and assume full responsibility for any misrepresented or falsified content, faulty references, plagiarism and breaches of data protection or copyright laws that may result from the use of generative AI.

I furthermore agree that the digital version of this thesis will be used to subject the paper to plagiarism examination.

Not this English translation but only the official version in German is legally binding.

Beim Verfassen dieser Arbeit habe ich die unten aufgeführten KI-Tools für folgende Zwecke verwendet:
In writing this paper, I have used the AI tools specified below for the following purposes:

Date	Simon Krahé	Signature

Contents

1 Introduction **1**
1.1 Motivation 1
1.2 Related Work 2

2 Work Packages **5**
2.1 Overview 5
2.2 WP-1 5
2.3 WP-2 6
2.4 WP-3 7
2.5 WP-4 8
2.6 WP-5 9
2.7 WP-6 9

3 Organization of this Thesis **11**

4 Timeline **13**
4.1 GanttChart Simple 13
4.2 GanttChart Detailed 15

Bibliography **17**

1 Introduction

ZUGFeRD is a standard for electronic invoices (e-invoices) that is used in Germany. It is quasi-identical to the French 'Factur-X' standard; they are being developed together. ZUGFeRD enables 'backwards compatible' digital invoicing by design: A ZUGFeRD-compliant file consists of a human-readable PDF with an XML-based attachment. The attachment contains the same invoice data as the PDF's text layer, but conforms to an existing schema (UN/CEFACT CII D22B-XML at the time of writing), enabling automatic digital processing of the invoice. At the same time, the document looks like a regular invoice in PDF format to a human user. ZUGFeRD is intended to ease the digital transformation and reduce administrative business cost. It is a national implementation of European Norm (EN) 16931.

The use of ZUGFeRD in business-to-business (B2B) transaction contexts is being phased in currently: German businesses are already obligated to accept e-invoices and will have to — with some exceptions — issue them starting 2027, or 2028.[5] ZUGFeRD is not the only e-invoicing standard in Germany, it is accompanied by "XRechnung", an XML-only standard that sees particular use in government contexts. ZUGFeRD, allowing users to work with a file format familiar to them (PDF), is intended to be more friendly to less technically minded users. ZUGFeRD offers a profile for XRechnung. Both formats are based on EN 16931 and thus closely related.

The master thesis will center around the use of ZUGFeRD from a security perspective. It will investigate compliance with the ZUGFeRD specification, as well as the potential for attacks in various validation centered software that utilizes ZUGFeRD. As ZUGFeRD uses PDF/A and XML, existing vulnerabilites that may apply in this context will be investigated as well.

1.1 Motivation

A security minded analysis of ZUGFeRD is highly relevant for several reasons. The use of ZUGFeRD is already obligatory in some business contexts with its use only increasing in the future. Additionally, any widely deployed technology should be sufficiently scrutinized, especially one that will see use in financial contexts, offering strong potential for abuse.

Furthermore, existing research (see 1.2) has already shown that ZUGFeRD includes multiple insecure-by-default technologies, such as XML, with tried-and-true exploits such as XML External Entity (XXE) injection being possible.[2] To prevent systematic abuse of ZUGFeRD for nefarious purposes, the security of its application should be analyzed, with fixes being identified and applied as soon as possible to reduce the potential for damage.

Finally, a study of the criteria for acceptance of ZUGFeRD outlined trust as a significant factor, calling for "trust building measures of risk minimization".[6, p. 19](own translation) The master thesis will be a contribution to this field. It will also serve to facilitate transparency into the security of the implementation of e-invoicing services, contributing to potential future quality standards. Both are desiderata identified by the study as well.[6, p. 21]

As such, the topic of the master thesis is highly relevant, and will not only serve as a contribution to the field of IT security but also the domain of e-invoicing and the digital transformation as a whole.

1.2 Related Work

There has only been one case of dedicated research into ZUGFeRD from a security perspective. Böck investigated ZUGFeRD as part of the entire system of e-invoicing, presenting the results in a talk,[7] a short writeup with supplementing material,[1] as well as an article in German tech magazine Golem.[2]. His conclusions were highly critical, scrutinizing the high complexity of the legal standardization of e-invoices, the fact that technologies (such as XML) involved in the realization of e-invoicing are insecure by default and that security seems to not have been a significant factor in the development of the ZUGFeRD standard. Böck identified and reported 14 XML External Entity (XXE) or Blind XXE attacks as of February 2026, expecting many more to exist.[2][7][1]

Any other existing research into the topic stems from a variety of views, such as a study by *eco - Verband der Internetwirtschaft* (Association of the Internet Industry), which focuses on strategy required to achieve broad acceptance of the standard. Among other points, they call for integration of processes that deal with e-invoices into existing business processes and applications.[6, p. 21] Other previous works are of legal nature or concerned with e-governance, which applies to the paper by Mueller-Toeroek and Schmidt. Its critical stance regarding the integrity of ZUGFeRD invoices,[13, pp. 38–40] however, is of particular relevance to a security-centered analysis of ZUGFeRD. Finally, the ZUGFeRD standard itself should be mentioned.[16] Notably, the chapter on security spans less than one page, highlighting the need for a thorough evaluation of ZUGFeRD and its application from a security standpoint.[16, p. 22]

Work that indirectly relates to ZUGFeRD, however, extends into the realms of the technologies the standard utilizes - PDF/A and XML, to be precise. Recent research into PDF can be split into two subtypes; that is, research that focuses on PDF and potential weaknesses within the standard or the relevant software and, on the other hand, research centered on detection of malware in PDF. The former is of higher relevance to this paper. Examples include attacks that circumvent PDF signature invalidation despite document modification,[12] self-modifying PDFs,[10] other attacks that exploit native PDF features,[15][19] content masking techniques that exploit PDFs character mapping functionalities,[11] breaking PDF encryption,[14] and more. There are a variety of further examples, including older research, but describing all would go beyond the scope of this exposee.[18][17][23] The other recent avenue of security research into PDF is centered around automated detection of malware in PDFs[8][22][9][4] and related obfuscation techniques.[3]

Similar to PDF, XML-based attacks are of relevance for this paper due to the use of XML in ZUGFeRD. While new instances of familiar vulnerabilites, such as the billion laugh attack, still occur and may remain unpatched,[2] research into them has subsided in recent years; good summaries are provided by a 2016 SoK[21] as well as a blog post centered around DTD attacks.[20]

2 Work Packages

2.1 Overview

The thesis is structured into six total work packages. The first step to assess ZUGFeRD validators from a security perspective is to create a systematic overview of the ZUGFeRD application landscape, with a particular focus towards validation. This will be followed by a security analysis of the underlying formats of ZUGFeRD — XML and PDF/A. The two work packages afterward will be centered around the creation of test documents for various cases — the conformance to existing specifications and vulnerability to existing attacks (1) as well as attacks that are specific to ZUGFeRD (2). The tests will be run together in the penultimate work package. Finally, the master thesis will have to be written, to the extent that this has not been done within the previous work packages.

2.2 WP-1

WP-1 is the **survey of the existing ZUGFeRD landscape with a particular focus on validation tools and services**. It aims to provide an overview over the ecosystem that the thesis will be concerned with. Besides traditional research into ZUGFeRD itself (consulting the specification, among other things), results from a systematic search across multiple search indexers will be aggregated. Search parameters will be a combination of certain keywords. A preliminary version of this aggregation already exists, outlining roughly 250 pages that warrant further reading. Since the list already has a considerable size, it is unlikely to be expanded to a larger extent. The final result of the overall work package will be a table of ZUGFeRD validators as well as other research artifacts in the form of notes or subsections in the master thesis. The work package is expected to take between 2.5 and 3 weeks of work. It consists of the following subpackages:

WP-1.1 Studying the ZUGFeRD specification. This step will be crucial to later test out specification adherence of the validators.

WP-1.2 Refining the search process and expanding queries. The existing list of potential tools (or websites that list these tools) is already quite long. Tests with other search terms have so far largely resulted only in resources that have already been found. This work package aims to finalize the list by adding the few instances that may have been missed with the previous search terms. Furthermore, AI-based search strategies will be employed as well.

WP-1.3 Filtering through the search results. The websites noted down will have to be studied. If the site in question offers a tool, it will have to be noted in the list of tools. The table will outline certain criteria for each tool (open/closed source, online/offline, free/paid, allows for creation of ZUGFeRD documents, allows for extraction of the attached XML, and so forth). According to these criteria, a subset of the tools will later be chosen to be tested.

WP-1.4 Researching the context of ZUGFeRD This applies to the (legal) history of ZUGFeRD, particularly in Germany, the European Norm it is based on, future plans for digital recordkeeping and tax applications (VAT-Reporting, VAT in the Digital Age (ViDA)), and other related topics that provide insights into why ZUGFeRD and tools that make use of it have developed to their current state. To prevent an open task like this from overshadowing other more relevant tasks, its duration is limited to two working days.

2.3 WP-2

WP-1 is the **security analysis of formats underlying ZUGFeRD.** It aims to provide an overview over the formats utilized in ZUGFeRD, outlining their individual weaknesses, how these have been exploited before and which of them are worthy to pursue further within the thesis. The packages consists of research into existing vulnerabilities of PDF, PDF/A, and XML, as well as a writeup of the results. The work package is expected to take between 6.5 and 7 weeks and will partially overlap with WP-3.

WP-2.1 Researching 'core' PDF attacks is the first item within the work package. "Core" refers to attacks with the highest likelihood of replication within the context of the master thesis. This means that implementation is relatively achievable, with exploitation of the flaw not relying on unlikely edge cases. An example would be incremental save attacks. Another aspect to consider at this point are ethical concerns connected to the use of the attack. This is, however, also dependent on the selection of services made in the previous work packages. This subpackage will be carried out in parallel to the creation of the corresponding tests (see 2.4)

WP-2.o1 Researching other PDF attacks is an *optional* work package. Should time permit, it would extend the pool of attacks to be tried, allowing for attacks that would otherwise not be the first choice.

WP-2.2 Researching PDF/A will include research into the particular differences from PDF/A to PDF and the applicability of the previous attacks. It will also include research into the PDF/A standard.

WP-2.3 Researching XML attacks will be largely based on existing summaries of the state of XML attacks.[21] This subpackage will be carried out in parallel to the creation of the corresponding tests (see 2.4)

WP-2.4 Writing the chapter "Previous Work".

2.4 WP-3

WP-3 is centered on **feature and compliance detection** within the validators. For the package, a variety of tests as well as supporting scripts will be created. These tests can then later be used to identify features and specification compliance on a granular level, with each test representing to one such item. Actually running the tests (besides some manual tests to ensure they are working as intended) is not part of this work package. The work package is expected to take a little less than 8 weeks, although the time span it will be worked on is larger than that due to some tasks being carried out in advance alongside tasks of WP-2.

WP-3.1 Writing a template invoice is the first step for this process. Depending on the software stack and versions of the underlying validation tools, some validation tools may warn about details in an invoice (such as a missing customer ID) that others will not. A true baseline document will need to be created that passes all known validators without issues. It will then be modified for the other tests.

WP-3.2 Scripting the invoice creation process is the next step to allow for reproducible and simple test generation. Ideally, the process will be as modular as possible.

WP-3.3 Writing a test documentation format to encode information like an expected result for a passing or failing test will help keep the tests reproducible. If possible, this should also be connected to the testing mechanism itself to allow for automated test result creation.

WP-3.4 Creating tests for PDF specific violations and attacks includes basic checks, such as whether PDF/A adherence is being enforced, as well as the previously researched attacks. These tests will be created while the corresponding vulnerabilites are being researched (see 2.3).

WP-3.5 Creating tests for XML specific violations and attacks will work analogously to the PDF chapter. Some previous work for this exists in the attack tests from Böck[1], which will be built on, if possible. These tests will be created while the corresponding vulnerabilites are being researched (see 2.3).

WP-3.o1 Creating tests for largely unused but spec-compliant features of ZUGFeRD and the underlying technologies is an *optional* subtask that would give insights into how far the specification is being followed by the validators in general.

WP-3.6 Creating tests for 'hard' ZUGFeRD violations is centered around the ZUGFeRD specification. Similar to the distinction made in earlier work packages, "hard" violations are in violation of the specification in crucial, particularly security relevant aspects. On example would be attaching arbitrary data other than the ZUGFeRD invoice to the PDF.

WP-3.o2 Creating tests 'soft' ZUGFeRD violations is an *optional* subtask that is the opposite to the previous one. Its focus lies on very slight violations to the ZUGFeRD standard, such as attaching two mutually exclusive XML-tags. The time for this subtask is limited with five working days. While certainly interesting, detailed analysis of the XML fields is a very large subject area. The focus of the master thesis should rather be on the hybrid character of ZUGFeRD rather than the intricacies of UN/CEFACT CII D22B validation.

WP-3.7 Documenting tests in the thesis itself is a seperate work item to the creation of the tests. This is because test creation is already being done in parallel with their research. Insights gained later into the test creation process may also lead to modification of earlier tests, warranting one clean write-up when all tests have been created.

2.5 WP-4

WP-4 is centered on the **investigation of hybrid-format attack surfaces.** This necessitates research into the attack vectors ZUGFeRD particularly enables - both in terms of its use cases and from a technical standpoint. WP-4 will take a little over 5 weeks.

WP-4.1 Researching ZF-specific attack vectors aims to answer the question how the use of ZUGFeRD may differ from attack scenarios that have been considered before. An example is the transmission of e-invoices using Pan-European Public Procurement OnLine (PEPPOL), a service specifically used for this purpose within the EU. As part of this subtask, PEPPOL and other relevant technologies, practices, and applications should be researched with the question of whether they contribute to new, ZUGFeRD-specific attack surfaces. This is an open task, limited at five working days.

WP-4.2 Creating ZF validator specific attacks is the technical counterpart to WP4.1.(**??**). It is another work package for writing tests. They are centered around the inherent hybrid nature of ZUGFeRD and potential exploits leveled at this structure. Examples are multiple attachments or mismatches between the human-readable PDF layer and the XML attachment. The subtask is explorative; the in-depth work with ZUGFeRD in the previous packages as well as the background research will provide approaches that may be tested here. Tests created in this package will also speak to the question of the hybrid attack surfaces. Multiple allowed attachments with inconsistent selection behavior by the validators, to stay with the previous example, are a prime example, as they would not occur with an XML-only format such as XRechnung.

2.6 WP-5

WP-5 will be **running the tests.** This means using the previously selected set of validators, having them validate the test files and noting the results. The package is expected to take 2.5 to 3 weeks.

WP-5.1 Creating results classifications will be a necessary step to ensure comparability between the results of different validators. The subtask will create a layer of abstraction on top of the validator UI, mapping the validation result to a previously defined outcome (hard fail, soft fail, ..., pass) depending on the output. This will have to be done on a per-validator basis.

WP-5.2 Writing 'core' automatic test scripts will enable automatic processing of tests. The 'core' group is understood as those validators that suit the thesis the best, be it from a perspective of access, usability with automated processing, widespread adoption, or other criteria such as ethical concerns.

WP-5.o1 Writing extra automated test scripts is an *optional* task that extends the group of validators with automated test processing to a wider set.

WP-5.3 Running tests and aggregating results is the final step, building on all previous tasks. The outcome of this subtask will be a table of results, clearly outlining vulnerabilites in the ZUGFeRD validator ecosystem.

2.7 WP-6

WP-6 will be **writing the thesis**, to the extent that this has not been done as part of the previous work packages, as well as other work items that should be grouped towards the end of the master thesis time frame. Approximately 5.5 weeks have been allocated for this work package.

WP-6.1 Writing the missing chapters will cover exactly those parts of the thesis. Example chapters are those outlining the approach to ethical testing, or takeaways from the results.

WP-6.2 Editing and aligning existing text will be required to create a presentable master thesis.

WP-6.3 Acquiring and applying feedback is another obligatory step in creation of a master thesis.

WP-6.X A **Buffer** is the final subtask. This subtask is not associated with any work per se. It is time kept in hand for when a task takes more time than expected, something not planned yet needs to be followed up with or other similar events occur. Furthermore, while the work packages were quite detailed, they cannot cover all the work required. Meta-processes, such as improving the working process for more efficient work overall, are hard to anticipate but should be made possible within the confines of a planned master thesis as well. An example of this would be familiarizing oneself with a literature management system *plugin* that improves organization and retrievability of stored papers.

3 Organization of this Thesis

Items in *italics* are placeholder names and will be changed later on.

1. Introduction
   1.1. Motivation
   1.2. Related Work
   1.3. Contribution
   1.4. Organization of this Thesis
2. Related Work
3. Background
   3.1. ZUGFeRD
   3.2. ZUGFeRD Validation Tools and Services
4. Existing Vulnerabilities in Technologies Used by ZUGFeRD
   4.1. PDF and PDF/A
   4.2. XML
5. ZUGFeRD Validator Tests
   5.1. Test Creation Process
   5.2. Compliance and Feature Tests
      2.5.1. Attack Vectors
      2.5.2. *Test 1*
      2.5.3. *Test 2*
      2.5.4. *Test 3*
      2.5.5. ...
   5.3. Hybrid Attack Surfaces
      3.5.1. (Novel) Attack Vectors Introduced by ZUGFeRD
      3.5.2. *Test 1*
      3.5.3. *Test 2*
      3.5.4. *Test 3*

3.5.5. ...

5.4. Testing Utility

6. Results

6.1. Test Result Criteria

6.2. Test Results

6.3. Security Evaluation of ZUGFeRD Validators

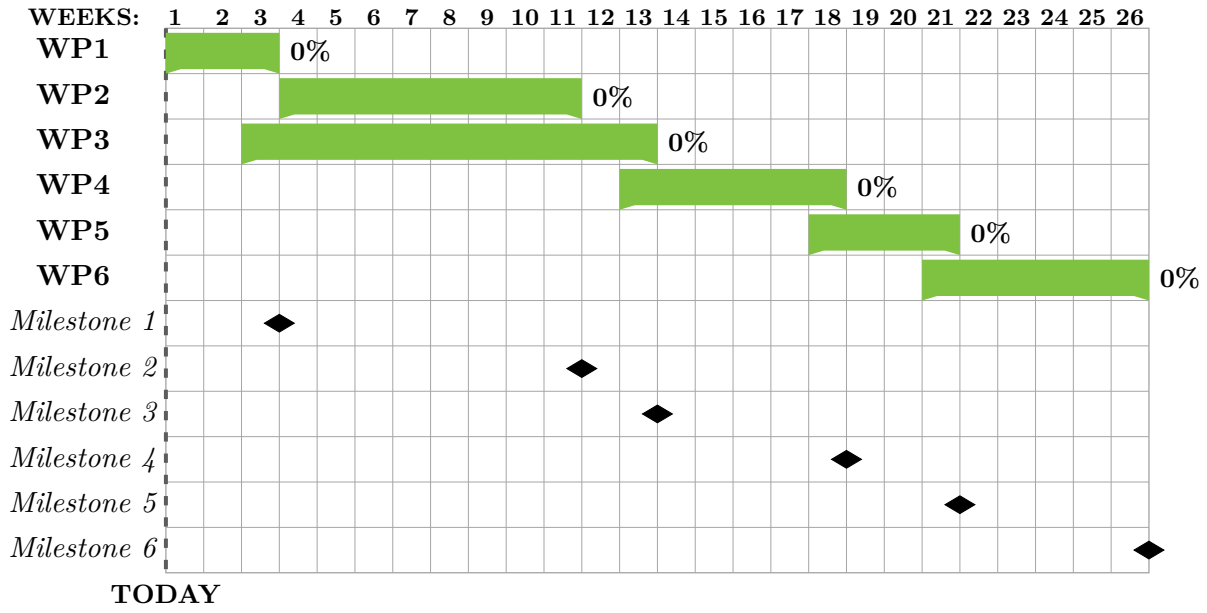
7. Conclusion and Future Work

7.1. Final Conclusion

7.2. Future Work

4 Timeline

4.1 GanttChart Simple



The milestones are as follows:

Milestone 1 A table of ZUGFeRD validators as well as other research artifacts in the form of notes or subsections in the master thesis.

Milestone 2 A write-up of the researched existing vulnerabilities of PDF, PDF/A, and XML.

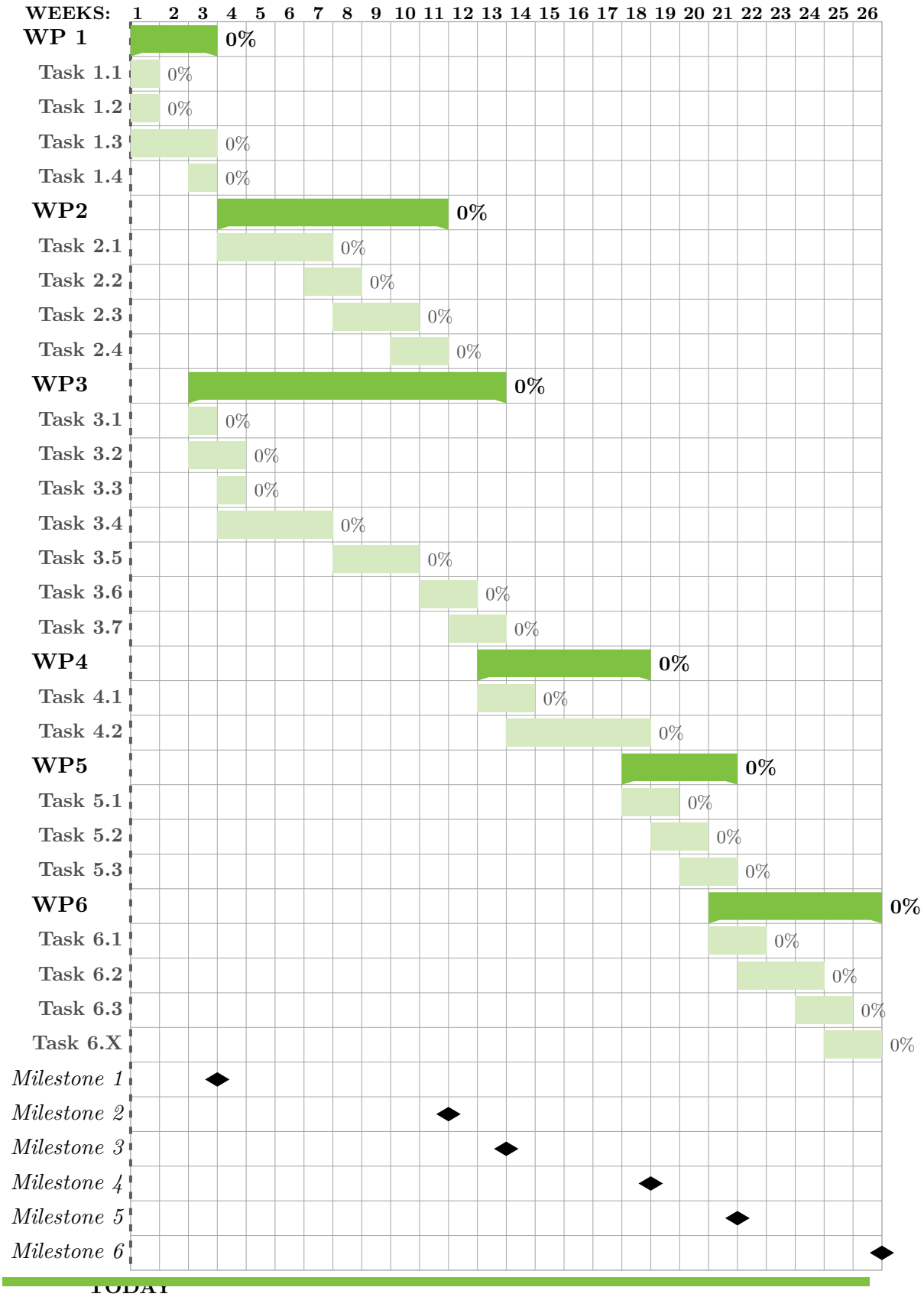
Milestone 3 A set of tests that can be used to test for feature and specification compliance.

Milestone 4 A set of tests that can be used to test for ZUGFeRD specific vulnerabilities in validators as well as an overview over ZUGFeRD-specific attack vectors.

Milestone 5 Test results in the form of a table, giving an overview over all tests and all validators.

Milestone 6 The finished master thesis.

4.2 GanttChart Detailed



Bibliography

[1] Hanno Böck. *Security Issues with Electronic Invoices and EU eInvoincing*. Feb. 16, 2026. URL: https://invoice.secvuln.info/ (visited on 05/30/2026).

[2] Hanno Böck. "Wie Elektronische Rechnungen Zum Sicherheitsrisiko Werden". In: *Golem IMHO* (Dec. 12, 2025). URL: https://www.golem.de/news/zugferd-xrechnung-und-co-wie-elektronische-rechnungen-zum-sicherheitsrisiko-werden-2512-202959.html#cmts (visited on 05/29/2026).

[3] Curtis Carmony, Mu Zhang, Xunchao Hu, Abhishek Vasisht Bhaskar, and Heng Yin. "Extract Me If You Can: Abusing PDF Parsers in Malware Detectors". In: *Proceedings 2016 Network and Distributed System Security Symposium*. Network and Distributed System Security Symposium. San Diego, CA: Internet Society, 2016. ISBN: 978-1-891562-41-9. DOI: 10.14722/ndss.2016.23483. URL: https://www.ndss-symposium.org/wp-content/uploads/2017/09/extract-me-if-you-can-abusing-pdf-parsers-malware-detectors.pdf (visited on 05/28/2026).

[4] Yizheng Chen, Shiqi Wang, Dongdong She, and Suman Jana. "On Training Robust PDF Malware Classifiers". In: *29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association, Aug. 2020, pp. 2343–2360. ISBN: 978-1-939133-17-5. URL: https://www.usenix.org/conference/usenixsecurity20/presentation/chen-yizheng.

[5] *Einführung Der E-Rechnung Ab Dem 1. Januar 2025*. Bayerisches Landesamt für Steuern. URL: https://www.lfst.bayern.de/steuerinfos/weitere-themen/e-rechnung (visited on 06/04/2026).

[6] Georg Rainer Hofmann and Meike Schumacher. *Akzeptanzfaktoren des E-Invoicing*. Köln: eco – Verband der Internetwirtschaft e.V., 2018. 26 pp.

[7] *How the EU Created Electronic Invoices without Considering Security*. Düsseldorf, Nov. 26, 2025. URL: https://media.ccc.de/v/god2025-56476-how-the-eu-created-electro (visited on 05/30/2026).

[8] Side Liu, Jiang Ming, Guodong Zhou, Xinyi Liu, Jianming Fu, and Guojun Peng. "Analyzing PDFs like Binaries: Adversarially Robust PDF Malware Analysis via Intermediate Representation and Language Model". In: *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*. CCS '25: ACM SIGSAC Conference on Computer and Communications Security. Taipei Taiwan: ACM, Nov. 19, 2025, pp. 1334–1348. ISBN: 979-8-4007-1525-9. DOI: 10.1145/3719027.3744829. URL: https://dl.acm.org/doi/10.1145/3719027.3744829 (visited on 05/28/2026).

[9] Side Liu, Jiang Ming, Yilin Zhou, Jianming Fu, and Guojun Peng. "VAPD: An Anomaly Detection Model for PDF Malware Forensics with Adversarial Robustness". In: *34th USENIX Security Symposium (USENIX Security 25)*. Seattle, WA: USENIX Association, Aug. 2025, pp. 4759–4778. ISBN: 978-1-939133-52-6. URL: https://www.usenix.org/conference/usenixsecurity25/presentation/liu-side.

[10] Christian Mainka, Vladislav Mladenov, and Simon Rohlmann. "Shadow Attacks: Hiding and Replacing Content in Signed PDFs". In: *Proceedings 2021 Network and Distributed System Security Symposium*. Network and Distributed System Security Symposium. Virtual: Internet Society, 2021. ISBN: 978-1-891562-66-2. DOI: 10.14722/ndss.2021.24117. URL: https://www.ndss-symposium.org/wp-content/uploads/ndss2021_1B-4_24117_paper.pdf (visited on 05/21/2026).

[11] Ian Markwood, Dakun Shen, Yao Liu, and Zhuo Lu. "PDF Mirage: Content Masking Attack against Information-Based Online Services". In: *26th USENIX Security Symposium (USENIX Security 17)*. Vancouver, BC: USENIX Association, Aug. 2017, pp. 833–847. ISBN: 978-1-931971-40-9. URL: https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/markwood.

[12] Vladislav Mladenov, Christian Mainka, Karsten Meyer Zu Selhausen, Martin Grothe, and Jörg Schwenk. "1 Trillion Dollar Refund: How To Spoof PDF Signatures". In: *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*. CCS '19: 2019 ACM SIGSAC Conference on Computer and Communications Security. London United Kingdom: ACM, Nov. 6, 2019, pp. 1–14. ISBN: 978-1-4503-6747-9. DOI: 10.1145/3319535.3339812. URL: https://dl.acm.org/doi/10.1145/3319535.3339812 (visited on 05/21/2026).

[13] Robert Mueller-Toeroek and Christoph Schmidt. "Implementing Mandatory E-Invoices B2B in Germany - Issues Obstacles and Probable Showstoppers". In: *Proceedings of the Central and Eastern European eDem and eGov Days 2024*. CEEeGov 2024: Central and Eastern European eDem and eGov Days 2024. Budapest Hungary: ACM, Sept. 12, 2024, pp. 38–41. ISBN: 979-8-4007-1709-3. DOI: 10.1145/3670243.3670246. URL: https://dl.acm.org/doi/10.1145/3670243.3670246 (visited on 05/21/2026).

[14] Jens Müller, Fabian Ising, Vladislav Mladenov, Christian Mainka, Sebastian Schinzel, and Jörg Schwenk. "Practical Decryption exFiltration: Breaking PDF Encryption". In: *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*. CCS '19: 2019 ACM SIGSAC Conference on Computer and Communications Security. London United Kingdom: ACM, Nov. 6, 2019, pp. 15–29. ISBN: 978-1-4503-6747-9. DOI: 10.1145/3319535.3354214. URL: https://dl.acm.org/doi/10.1145/3319535.3354214 (visited on 05/28/2026).

[15] Jens Müller, Dominik Noss, Christian Mainka, Vladislav Mladenov, and Jörg Schwenk. "Processing Dangerous Paths – On Security and Privacy of the Portable Document Format". In: *Proceedings 2021 Network and Distributed System Security Symposium*. Network and Distributed System Security Symposium. Virtual: Internet Society, 2021. ISBN: 978-1-891562-66-2. DOI: 10.14722/ndss.2021.23109. URL: https://www.ndss-symposium.org/wp-content/uploads/ndss2021_1B-2_23109_paper.pdf (visited on 05/21/2026).

[16] Monique Ostermann, Klaus Förderer, Jochen Stärk, Gerhard Heemskerk, Jörg Walther, Svante Schubert, Andreas Starke, Alexander Geller, Andreas Pelekies, and Tobias Kellermann. "ZUGFeRD v. 2.4 (Factur-X Version 1.08)". In: *Infopaket für das E-Rechnungsformat ZUGFeRD 2.4 vom 04.12.2025* (Dec. 4, 2025). URL: https://www.ferd-net.de/publikationen-produkte/publikationen/detailseite/zugferd-24-deutsch (visited on 05/28/2026).

[17] Dan-Sabin Popescu. *Hiding Malicious Content in PDF Documents*. Jan. 1, 2012. DOI: 10.48550/arXiv.1201.0397. arXiv: 1201.0397 [cs.CR]. URL: http://arxiv.org/abs/1201.0397 (visited on 05/28/2026). Pre-published.

[18] Frédéric Raynal, Guillaume Delugré, and Damien Aumaitre. "Malicious Origami in PDF". In: *Journal in Computer Virology* 6.4 (Nov. 2010), pp. 289–315. ISSN: 1772-9890, 1772-9904. DOI: 10.1007/s11416-009-0128-2. URL: http://link.springer.com/10.1007/s11416-009-0128-2 (visited on 05/28/2026).

[19] Simon Rohlmann, Vladislav Mladenov, Christian Mainka, and Jörg Schwenk. "Breaking the Specification: PDF Certification". In: *2021 IEEE Symposium on Security and Privacy (SP)*. 2021 IEEE Symposium on Security and Privacy (SP). San Francisco, CA, USA: IEEE, May 2021, pp. 1485–1501. ISBN: 978-1-7281-8934-5. DOI: 10.1109/SP40001.2021.00110. URL: https://ieeexplore.ieee.org/document/9519390/ (visited on 05/21/2026).

[20] Christopher Späth, Christian Mainka, and Vladislav Mladenov. *DTD Cheat Sheet*. On Web-Security and -Insecurity. Mar. 2, 2016. URL: https://web-in-security.blogspot.com/2016/03/xxe-cheat-sheet.html (visited on 05/21/2026).

[21] Christopher Späth, Christian Mainka, Vladislav Mladenov, and Jörg Schwenk. "SoK: XML Parser Vulnerabilities". In: *10th USENIX Workshop on Offensive Technologies (WOOT 16)*. Austin, TX: USENIX Association, Aug. 2016. URL: https://www.usenix.org/conference/woot16/workshop-program/presentation/spath.

[22] Nedim Šrndic and Pavel Laskov. "Detection of Malicious Pdf Files Based on Hierarchical Document Structure". In: *Proceedings of the 20th Annual Network & Distributed System Security Symposium*. Citeseer, 2013, pp. 1–16.

[23] Dat Tran and Chetan Jaiswal. "PDFPhantom: Exploiting PDF Attacks Against Academic Conferences' Paper Submission Process with Counterattack". In: *2019 IEEE 10th Annual Ubiquitous Computing, Electronics & Mobile Communication Conference (UEMCON)*. 2019 IEEE 10th Annual Ubiquitous Computing, Electronics & Mobile Communication Conference (UEMCON). New York City, NY, USA: IEEE, Oct. 2019, pp. 0736–0743. ISBN: 978-1-7281-3885-5. DOI: 10.1109/UEMCON47517.2019.8992996. URL: https://ieeexplore.ieee.org/document/8992996/ (visited on 05/28/2026).